MDM GRC READINESS & CONTROL ASSURANCE CASE STUDY

MDM-D06

Mobile Device and BYOD Policy

Deliverable 6 of 15 in a portfolio case study on readiness and control assurance for mobile access to Microsoft 365 at a fictional 850-employee Saudi financing company. Cross-references to other deliverables use their MDM-D numbers.

Prepared by
Ali Fathi Aldhabiki
Cybersecurity Governance, Risk & Compliance (GRC)
linkedin.com/in/ali-aldhabiki-a74354212 | ali.f.aldhabiki@outlook.com

Notice
The organization is fictional. No Microsoft Intune or Entra ID tenant was configured; all evidence, test results and ratings are simulated.

Mobile Device and BYOD Policy

MDM-D06

1. Purpose

This policy defines requirements and responsibilities for secure mobile access to corporate services, protection of corporate information, and authorized use of company-owned and personal mobile devices.

2. Scope

This policy applies to employees using company-owned or approved personal Android and iOS/iPadOS devices, and contractors using company-issued devices, to access Microsoft 365 email, meetings, collaboration and work documents.

Company-owned devices are managed through Microsoft Intune MDM. Personal devices use Intune App Protection without MDM enrollment. BYOD participation is voluntary, limited to eligible employees and subject to prior approval. Microsoft Entra ID provides authentication and Conditional Access decisions.

The policy also covers responsibilities for administering the in-scope mobile service and handling employee device management reports.

Windows and macOS devices, core financing and payment operations, and privileged administrative sessions from mobile devices are outside the permitted scope of this service.

3. Roles and Responsibilities

The responsibilities below complement the assessment RACI in MDM-D02 and the control-specific assignments in MDM-D05.

Role	Responsibilities
CISO	Oversee security requirements and control assurance. Provide cybersecurity approval for mobile access policy changes and perform access approvals and reviews assigned in MDM-D05.
GRC Analyst	Define and maintain policy requirements, review supporting evidence, test controls, document findings and retest remediation in accordance with MDM-D02.
IT Operations Manager	Oversee operational implementation, technical evidence submission and remediation. Perform assigned access approvals and reviews, and ensure unresolved operational issues are tracked and escalated.

Role	Responsibilities
IT Operations Team	Implement and operate technical controls, verify applicable requirements before enabling access, provide evidence and perform remediation. Execute access revocation, device handling and report preparation and review activities as assigned.
Employee's Line Manager	Approve the business need for employee BYOD access. Approval does not replace verification of applicable security and access requirements.
Designated Internal Sponsor	Maintain contractor authorization details, promptly notify IT Operations of departures or changes, coordinate timely extension approvals and arrange company device recovery.
Responsible Business Manager	Approve contractor authorization extensions before the existing authorization expires. Pending approval must not delay access revocation.
Business Owner	Approve the business impact of mobile access policy changes before submission to CAB.
Change Advisory Board (CAB)	Authorize mobile access policy changes before deployment, following Business Owner and CISO approvals under the corporate change management process.
Employees and Contractors	Follow this policy, protect assigned devices and corporate information, use only authorized access methods, promptly report loss or suspected compromise, and cooperate with access removal and applicable device return requirements.

No individual may approve or review their own access. Detailed approval, review and verification assignments remain as specified in MDM-D05.

4. Authorized Use and Access

Access to in-scope corporate services must meet the following requirements:

Area	Policy Requirement
Authorized Use	Users must use approved work applications and individually assigned corporate accounts for authorized business purposes. Access through mobile web browsers

Area	Policy Requirement
	is not permitted within this service.
Company-Owned Devices	Devices must be enrolled in Microsoft Intune MDM and have a valid compliant status against applicable security requirements before access is granted. Enrollment alone is insufficient.
Personal Devices (BYOD)	Access is voluntary, limited to eligible employees and subject to prior line manager approval. Approved work applications must meet applicable App Protection and access requirements without MDM enrollment.
Contractor Access	Contractors must use company-issued devices. Access must remain within the approved business need and authorization period.
User Obligations	Users must not share account credentials, bypass access restrictions or disable required security protections.

5. Device and Corporate Data Protection

Area	Policy Requirement
Company-Owned Devices	Devices must meet defined passcode, automatic lock, operating system and security update requirements. Users must not remove MDM enrollment or disable required protections without authorization from IT Operations.
BYOD Data Protection	Corporate data must remain within approved work applications, corporate accounts and storage locations where required protection is maintained. Saving, sharing or copying and pasting corporate data to personal or unapproved destinations is prohibited.
Encryption	Corporate data must be encrypted at rest and in transit. Applicable encryption requirements for company-owned devices and BYOD work applications must be defined and technically validated in MDM-D07.
Security Remediation	Users must cooperate with IT Operations to resolve security issues. Access must not be restored until applicable protection and access requirements are satisfied.

Area	Policy Requirement
Corporate Data Removal	Users must cooperate with authorized corporate data removal when access ends or protective action is required. For BYOD, removal must target corporate data within approved work applications and must not include personal data or a full-device wipe.

6. Privacy and Device Reporting

Area	Policy Requirement
Information Collection and Use	Collection and use of employee, device and application information must be limited to what is necessary for mobile service security and operation.
BYOD Notice and Acknowledgment	Before BYOD access is enabled, employees must receive and acknowledge a notice explaining the information available to the company, its purposes, and protective actions that may affect corporate data or access. Acknowledgment must not be treated as unrestricted permission to access personal data.
Report Access and Sharing	Employee device reports must be stored in an approved repository and restricted to authorized individuals with a documented business need. Read, update and access-management permissions must be separately controlled. Broad internal sharing is prohibited.
Access Review	Report permissions and sharing links must be reviewed at least every three months and when responsibilities or business needs change. Unnecessary access must be removed, and no individual may approve or review their own access.
Report Accuracy	Manually compiled device compliance reports must preserve each device identifier's association with its compliance status. Another IT Operations team member must verify these mappings against source records before release. Errors must be corrected and rechecked, with review and

Area	Policy Requirement
	correction evidence retained.

7. Incident Reporting and Offboarding

Area	Policy Requirement
Incident Reporting	Users must immediately report device loss, theft, suspected compromise or unintended corporate data disclosure to IT Operations through the designated reporting channel and cooperate with response instructions.
Incident Handling	IT Operations must escalate reported incidents through the corporate incident management process and coordinate authorized protective actions. Actions and outstanding issues must be documented.
Contractor Authorization	Each contractor must have a designated internal sponsor and a recorded authorization end date and time. The sponsor must immediately notify IT Operations of early departures or changes to the agreed end time.
Reminders and Extensions	Automated reminders must be sent to the sponsor one month before authorization expires and weekly thereafter until expiry. Extensions require responsible business manager approval and recording before expiry. Missing responses or pending requests must not delay revocation.
Access Revocation	Access must be revoked when authorization ends, including at a revised end time for early departures. IT Operations must address relevant accounts, application permissions and existing sessions, and verify that access to in-scope services is blocked.
Device Return and Data Handling	The sponsor must coordinate contractor device return. IT Operations must record receipt and handle corporate data under approved retention and secure removal procedures. Access revocation must not wait for device recovery. BYOD data removal remains subject to Section 5.

Area	Policy Requirement
Verification and Follow-up	Access removal and device recovery must be tracked separately. Failed or incomplete revocation must be immediately escalated to the IT Operations Manager. Unreturned devices must be escalated for protective action. Removal commands must not be treated as completed without confirmation.

8. Policy Governance

Area	Policy Requirement
Policy Maintenance and Review	The GRC Analyst must maintain this policy under CISO oversight. It must be reviewed periodically and following material changes to service scope, risks or applicable requirements. Policy approval must follow the corporate policy governance process.
Exceptions	Exceptions must document the business justification, affected requirements, scope, owner, risk assessment, compensating measures where applicable, and expiry date. CISO security review and risk acceptance by the authorized corporate risk acceptance authority are required before activation. A pending request does not authorize non-compliance.
Exception Expiry and Follow-up	Exceptions must be tracked and reviewed before expiry. They must not remain active beyond expiry without renewed assessment and approval. Required corrective actions must have assigned owners and target dates.
Scope Changes	Exceptions must not authorize activities excluded from the service scope. Such activities require formal scope review and assessment of the associated risks and control design before authorization.
Access Policy Changes	Changes must follow the corporate change management process and MDM-CTL-004, including impact assessment, testing, Business Owner and CISO approvals, CAB authorization before deployment, rollback planning and post-

Area	Policy Requirement
	implementation verification.
Supporting Design and Assurance	Technical requirements must be specified in MDM-D07 and Conditional Access design in MDM-D08. Policy documentation alone does not demonstrate implementation or effectiveness; these require supporting evidence and control testing.